

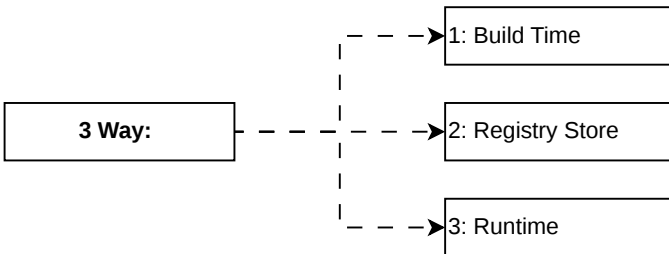
Image Security

Container Image Security

Container Image - jab hm koi application ko container mai run krte hai,

1 container k ander kya kya ho skta hai - Processor, OS, Packages, libraries, code

innhi mai se khi koi loophole (vulnerability) ho skta hai



Build Time Security:

A: Base Image: Minimal Size (Alpine/google Distrosless - shell bhi nhi hoti)

B: Root User use nhi karna hai: by default docker ke andar sb kuch root user k roop kaam hota hai
non-root user create krna hota hai.

C: Secrete Hardcoded nhi likhne hai docker file mai: API KEY/Database URL, Password nhi honi chahiye
docker file mai.

kha se leni hia ye: ENV Variables, Key Vault Use kro y fir k8s secrete ka use kr kste hai.

D: Multi Stage Build

Registry Store (Security):

Docker Hub, ACR, GCP GCR, AWS ECR

A: Private Registry & Access Control

B: Vulnerability Scanning: CVE Scan: Tool - Trivy, Clair, Snyk, prisma -> CI/CD Pipeline -> Fail

Docker Build -> Image -> SCAN -> Push ACR

C: Image Signing: (tool Cosign/notary)

(Docker content Trust):

Deployment & Runtime Security:

API Server: Admission Controller: OPA Gatekeeper / Kyverno: policies set kr skte hai:

1: Kya image mai sign lga hua hai y nhi lga hua hai

2: kya ye image hmari private registry se hi aa rhi hai y khi or public registry se aa rhi hai?

Read Only Root File System: aapka container ko asia setting ke sath chlaya ki hacker ander aa gya
toh bhi wo koi script pull, download nhi kr payega.

C: DROP Capability: LINUX Container: OS Level pr koi vi special power nhi deni hai

securitycontext: DROP: ["ALL"]

Tool Summary:

1: Image Scan: Trivy, Chair, Prisma

2: Image Sign: Sigstore (Cosign), Docker Content trust

3: K8's policy: Admission Controller: OPA Gatekeeper, Kyverno

4: Base Image: Alpine, Google distroless